Web Application Security Assessment

127.0.0.1

Scan ID: 3705ddfd-d476-415d-948a-57a045d1de72

Assessment date: 2026-08-06 11:16 UTC – 2026-08-06 11:16 UTC

Initiated by: cli-user

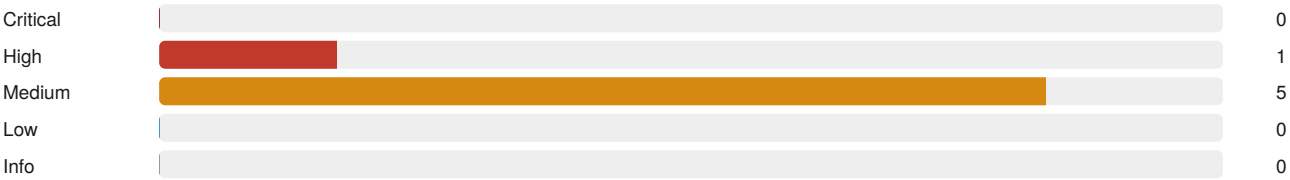
Authorization reference: N/A

Pages crawled: 2

Report generated: 2026-08-06 11:16

Executive Summary

This report summarizes the results of an authorized automated security assessment of **127.0.0.1**, conducted between 2026-08-06 11:16 UTC and 2026-08-06 11:16 UTC. The assessment identified **6** finding(s) across 2 crawled page(s), summarized by severity below.



Scope & Methodology

Testing was performed using an automated, template-driven scanner covering common misconfiguration, information disclosure, and injection classes (OWASP Top 10-aligned). Both passive checks (response header analysis) and active, non-destructive checks (path probing, marker-based reflection testing) were used. All active checks avoid real exploitation payloads; findings marked as "candidate" required a confirmation pass before being included in this report.

Limitations: automated scanning does not replace manual penetration testing for business-logic flaws, complex authentication/authorization issues, or multi-step attack chains.

Findings Summary

Severity	Title	CVSS	Affected URL
HIGH	Exposed .git Directory	7.5	http://127.0.0.1:8899/
MEDIUM	Reflected Cross-Site Scripting (candidate)	6.1	http://127.0.0.1:8899/search?q=test
MEDIUM	Server Version/Technology Disclosure	5.3	http://127.0.0.1:8899/
MEDIUM	Missing Security Headers	5.3	http://127.0.0.1:8899/
MEDIUM	Server Version/Technology Disclosure	5.3	http://127.0.0.1:8899/search?q=test
MEDIUM	Missing Security Headers	5.3	http://127.0.0.1:8899/search?q=test

Detailed Findings

1. Exposed .git Directory

HIGH

CVSS 3.1: 7.5 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |

AFFECTED ASSET

http://127.0.0.1:8899/

DESCRIPTION

The application exposes its .git directory, potentially allowing an attacker to reconstruct source code, commit history, and secrets accidentally committed to the repository.

EVIDENCE

```
GET http://127.0.0.1:8899/.git/HEAD
HTTP 200 at http://127.0.0.1:8899/.git/HEAD; body snippet: 'ref: refs/heads/main '
```



REMEDIATION

Block access to .git and other VCS metadata directories at the web server level, and ensure they are never deployed to production webroots.

2. Reflected Cross-Site Scripting (candidate)

MEDIUM

CVSS 3.1: 6.1 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N |

AFFECTED ASSET

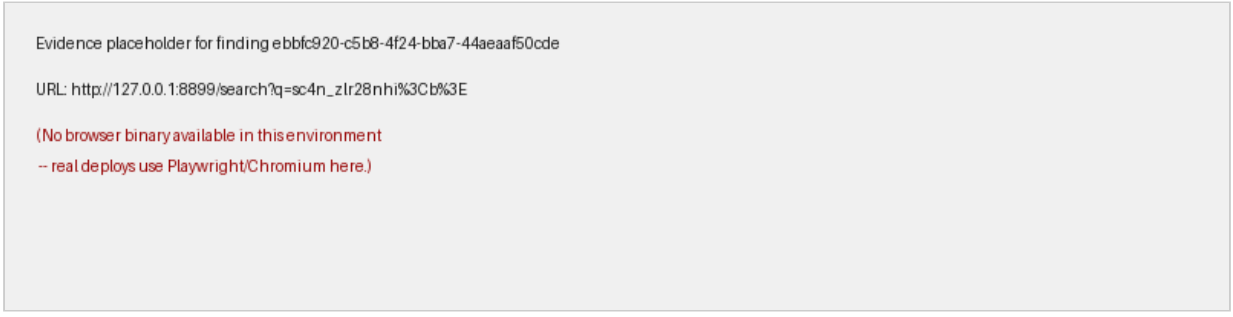
http://127.0.0.1:8899/search?q=test

DESCRIPTION

A unique marker injected into a query parameter was reflected back in the HTTP response without HTML-encoding, indicating the parameter may be vulnerable to reflected XSS.

EVIDENCE

```
GET http://127.0.0.1:8899/search?q=sc4n_zlr28nhi%3Cb%3E
Marker 'sc4n_zlr28nhi' reflected unescaped in response body at http://127.0.0.1:8899/search?
q=sc4n_zlr28nhi%3Cb%3E
```



REMEDIATION

Context-appropriately encode/escape all user-supplied input before reflecting it into HTML, JS, or attribute contexts. Prefer a templating engine with auto-escaping enabled, and deploy a Content-Security-Policy as defense in depth.

3. Server Version/Technology Disclosure

MEDIUM

CVSS 3.1: 5.3 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |

AFFECTED ASSET

http://127.0.0.1:8899/

DESCRIPTION

The Server or X-Powered-By response header discloses specific software and version information, which can help an attacker fingerprint the stack and target known CVEs.

EVIDENCE

```
GET http://127.0.0.1:8899/
Server: BaseHTTP/0.6 Python/3.12.3, Apache/2.2.15 (CentOS)
```

Evidence placeholder for finding 5696493a-e3d8-4c91-9af9-030cc7cd6f5f

URL: http://127.0.0.1:8899/

(No browser binary available in this environment
-- real deploys use Playwright/Chromium here.)

REMEDIATION

Suppress or genericize the Server/X-Powered-By headers at the web server / reverse proxy layer.

4. Missing Security Headers

MEDIUM

CVSS 3.1: 5.3 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N |

AFFECTED ASSET

http://127.0.0.1:8899/

DESCRIPTION

The response does not set recommended security headers, which can increase exposure to clickjacking, MIME-sniffing, and downgrade attacks.

EVIDENCE

```
GET http://127.0.0.1:8899/
Missing headers: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security
```

Evidence placeholder for finding b4cd8223-5c4c-4f23-b166-3d2640a1524a

URL: http://127.0.0.1:8899/

(No browser binary available in this environment
-- real deploys use Playwright/Chromium here.)

REMEDIATION

Configure the web server or application framework to send Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, and Strict-Transport-Security headers on all responses.

5. Server Version/Technology Disclosure

MEDIUM

CVSS 3.1: 5.3 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |

AFFECTED ASSET

http://127.0.0.1:8899/search?q=test

DESCRIPTION

The Server or X-Powered-By response header discloses specific software and version information, which can help an attacker fingerprint the stack and target known CVEs.

EVIDENCE

```
GET http://127.0.0.1:8899/search?q=test
Server: BaseHTTP/0.6 Python/3.12.3
```

Evidence placeholder for finding a0dbcd8a-e40b-41c2-a767-4deba77708f1

URL: http://127.0.0.1:8899/search?q=test

(No browser binary available in this environment
-- real deploys use Playwright/Chromium here.)

REMEDIATION

Suppress or genericize the Server/X-Powered-By headers at the web server / reverse proxy layer.

6. Missing Security Headers

MEDIUM

CVSS 3.1: 5.3 | Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N |

AFFECTED ASSET

http://127.0.0.1:8899/search?q=test

DESCRIPTION

The response does not set recommended security headers, which can increase exposure to clickjacking, MIME-sniffing, and downgrade attacks.

EVIDENCE

```
GET http://127.0.0.1:8899/search?q=test
Missing headers: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security
```

Evidence placeholder for finding 0cfa86cc-0f2e-4b7d-adc8-fb96070bf744

URL: http://127.0.0.1:8899/search?q=test

(No browser binary available in this environment
-- real deploys use Playwright/Chromium here.)

REMEDIATION

Configure the web server or application framework to send Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, and Strict-Transport-Security headers on all responses.

Appendix: Crawled Assets

URL	Status	Discovered Via
http://127.0.0.1:8899/	200	crawl
http://127.0.0.1:8899/search?q=test	200	crawl